



**Before the
CALIFORNIA PRIVACY PROTECTION AGENCY
Sacramento, CA 95834**

COMMENTS

of the

ANA – ASSOCIATION OF NATIONAL ADVERTISERS

on the

**INVITATION FOR PRELIMINARY COMMENTS ON PROPOSED RULEMAKING
CYBERSECURITY AUDITS, RISK ASSESSMENTS, AND AUTOMATED
DECISIONMAKING
PR 02-2023**

Christopher Oswald
EVP for Law, Ethics, & Govt. Relations
Association of National Advertisers
2020 K Street, NW
Suite 660
Washington, DC 20006
202.296.2066

Counsel:
Stu Ingis
Tara Sugiyama Potashnik
Allaire Monticollo
Venable LLP
600 Massachusetts Ave., NW
Washington, DC 20001
202.344.4613

March 27, 2023

On behalf of the Association of National Advertisers (“ANA”), we provide input (“Comments”) below in response to the California Privacy Protection Agency’s (“CPPA” or “Agency”) request for preliminary comments on its proposed rulemaking related to cybersecurity audits, risk assessments, and automated decisionmaking (“RFC”).¹ As America’s oldest and largest advertising trade association, the ANA has long supported brands, advertisers, marketing service providers, and countless other entities that engage in advertising in their mission to connect consumers with relevant messaging, products, and services. We assist our member companies in their efforts to address applicable legal obligations, including by helping members identify appropriate data governance activities and by encouraging members to maintain relevant documentation related to the topics set forth in the RFC. We thank the Agency for the opportunity to respond to its request for preliminary comments on these important topics.

The mission of the ANA is to drive growth for marketing professionals, brands and businesses, the industry, and humanity. The ANA serves the marketing needs of 20,000 brands by leveraging the 12-point ANA Growth Agenda, which has been endorsed by the Global CMO Growth Council. The ANA’s membership consists of U.S. and international companies, including client-side marketers, nonprofits, fundraisers, and marketing solutions providers (data science and technology companies, ad agencies, publishers, media companies, suppliers, and vendors). The ANA creates Marketing Growth Champions by serving, educating, and advocating for more than 50,000 industry members that collectively invest more than \$400 billion in marketing and advertising annually. Our members include small, mid-size, and large firms, and virtually all of them engage in or benefit from data-driven advertising practices that give consumers access to relevant information, messaging, and advertisements at the right time and in the right place.

Our Comments proceed by first discussing the Agency’s regulatory mandate under the text of the California Consumer Privacy Act (“CCPA”) itself. We urge the CPPA to critically consider and clearly define which processing activities present a “significant risk” to consumer privacy or security. We then address the topics of cybersecurity audits and risk assessments and encourage the Agency to promote flexible regulatory standards that can be tailored to the nature of the personal information processed and the size, sophistication, and resources available to regulated entities. Finally, we recommend that the Agency’s proposed rules related to automated decisionmaking align with existing requirements in other jurisdictions to promote consumer opt-out rights for the benefit of all Californians and harmonize with the approach to privacy choices taken by the CCPA. Overall, we emphasize that the CPPA must remain within the bounds of its regulatory authority when promulgating rules related to cybersecurity audits, risk assessments, and automated decisionmaking. We ask the Agency to promote flexibility, interoperability, and clarity in regulatory requirements tied to such topics.

¹ California Privacy Protection Agency, *Invitation for Preliminary Comments on Proposed Rulemaking – Cybersecurity Audits, Risk Assessments, and Automated Decisionmaking* (Feb. 10, 2023), located [here](#) (hereinafter, “RFC”).

I. The Agency's rules related to cybersecurity audits and risk assessments should be clearly defined and must address processing activities that present a "significant risk" to consumer privacy or security.

The CCPA specifically authorizes the Agency to "issu[e] regulations requiring businesses whose processing of consumers' personal information presents *significant risk* to consumers' privacy or security" to perform cybersecurity audits and risk assessments.² Regulations related to cybersecurity audits and risk assessments should clearly define which activities present a significant risk to consumers and should refrain from extending the concept of "significant risk" to routine, reasonable, and expected data processing activities. "Significant risk" is a higher standard than "risk" alone, and the Agency should acknowledge as much in its regulations.

Additionally, the Agency should place auditing and assessment requirements on only those *processing activities* that present a significant risk to consumers' privacy or security, rather than businesses' data processing practices as a whole. Such a regulation would help ensure the processing activity that actually presents the significant risk to consumers is appropriately scrutinized and analyzed in an assessment or audit. Auditing and assessment requirements should be imposed only for business processing activities that present a significant risk to consumer privacy or security.

Finally, the CPPA should prioritize clarity in its rules related to cybersecurity audits and risk assessments. To promote such clarity, the Agency should consider plainly defining "significant risk" to mean "personal information processing that (A) results in demonstrable and quantifiable harm to a consumer, and (B) is completed to determine that a consumer is ineligible for any of the following benefits: employment, credit, insurance, health care, education admissions, financial aid, or housing, except as permitted under other applicable laws."³

Processing decisions impacting the aforementioned critical areas may reasonably be subject to additional data governance processes, such as cybersecurity audits or risk assessments, given that the consequences of those processing decisions may impose a heightened risk to consumers. Other processing activities, such as routine data processing to facilitate advertising, do not present a similarly *significant risk* to consumer privacy or security. Moreover, such processing activities should be subject to auditing and assessment requirements only if they may result in actual, tangible harm to consumers. Including such a harm requirement in the definition of "significant risk" would reduce the need for businesses to complete assessments or audits for processing activities do not present any sort of risk of harm to consumers. The Agency should prioritize drafting a clear definition of what constitutes "significant risk," and including a harm standard in its definition, as such clarity will help businesses accurately evaluate when cybersecurity audits and risk assessments are required under California law.

² Cal. Civ. Code § 1798.185(a)(15) (emphasis added).

³ See generally Civil Rights Act of 1964, 42 U.S.C. § 2000d et seq.; Fair Housing Act, 42 U.S.C. § 3601 et seq.; Fair Credit Reporting Act, 15 U.S.C. § 1681 et seq.; Equal Credit Opportunity Act, 15 U.S.C. § 1691 et seq.; Americans with Disabilities Act, 42 U.S.C. § 12101 et seq.

II. Regulatory requirements related to cybersecurity audits and risk assessments should be appropriately tailored to businesses' size and sophistication and should be interoperable with similar requirements under other laws.

The CPPA's regulations related to audits and assessments should not impose one-size-fits-all mandates on businesses. Regulations should instead focus on promoting flexibility so that businesses of all sizes can meet applicable requirements, even in the face of potentially unavoidable constraints they may face in terms of staff and time available to dedicate to audits and assessments. When determining the scope of audit and assessment requirements, the Agency should keep in mind the fact that smaller businesses may not have as many resources to contribute to data governance requirements as their larger business counterparts. The Agency's requirements should thus be clear and tailored to the size and complexity of the business and the nature and scope of data processing activities.

Existing laws place requirements on businesses to conduct cybersecurity audits and risk assessments related to data processing. The Agency's RFC specifically asks about the benefits and drawbacks related to accepting audits and assessments businesses have completed to comply with such other laws.⁴ One significant benefit of accepting such audits and assessments would be simplifying compliance for companies who are already required to complete audits and assessments under different legal regimes. The Agency should accept audits and assessments conducted to satisfy other laws, such as the European Union's General Data Privacy Regulation (GDPR), the Connecticut Data Privacy Act, the Colorado Privacy Act, and the Virginia Consumer Data Protection Act.⁵ A regulation stating that the Agency will accept cybersecurity audits and risk assessments issued under other relevant state or federal laws or standards-setting bodies would provide clarity and consistency for businesses operating in California.

The Agency should also clarify that any documentation it collects from businesses as part of the audit and assessment requirements remains protected under applicable work product and/or attorney-client privilege doctrines. This approach has been adopted by virtually every other state that has required risk assessments related to data processing activities.⁶ Attorney-client privilege and work product protections create a sphere of safety surrounding businesses' confidential conversations with their legal representatives. These protections help ensure that companies seeking advice or aid from attorneys can be completely open and frank with their counsel, which facilitates better outcomes for consumers, businesses, and society overall. Ensuring businesses' work product and attorney-client privilege protections remain in-tact in the context of auditing and assessment requirements will ensure the foundational purposes for such protections continue to be prioritized.

III. Regulations related to automated decisionmaking should promote meaningful transparency and an opt-out regime to align with the text of the CCPA.

We encourage the Agency to ensure its requirements related to automated decisionmaking reflect the regulatory directive set forth in the CCPA and align with similar

⁴ RFC at Section I(3), Section II(5).

⁵ E.U. General Data Protection Regulation at Art. 35; Conn. Gen. Stat. § 42-522; Colo. Rev. Stat § 6-1-1309; Va. Code Ann. § 59.1-580.

⁶ *Id.*

requirements in other states. Specifically, the law tasks the Agency with issuing regulations “governing access and opt-out rights with respect to businesses’ use of automated decision making technology.”⁷ As a result, the CPPA should ensure its regulations promote transparency that will be useful and meaningful to consumers regarding automated decisionmaking processes, as well as provide opt-out choices for such processing.

Access requirements related to automated decisionmaking should provide consumers with useful and understandable information about applicable practices while ensuring businesses’ proprietary information and trade secrets remain protected. In particular, the CCPA states the Agency may promulgate rules requiring businesses to include “a description of the likely outcome of the [automated decisionmaking] process with respect to the consumer.” Any such requirements should be limited to providing a description of potential outcomes and results for consumers writ-large rather than requiring businesses to individualize responses to specific consumers by guessing at the outcome of the process prior to it being initiated or finalized.

The CCPA also states the Agency may promulgate rules requiring businesses to include “meaningful information” about the logic involved in automated decisionmaking processes in response to a consumer access request.⁸ Access rights should be appropriately tailored to promote transparency while refraining from requiring businesses to divulge trade secrets or other protected business information. The Agency should balance the need to promote meaningful transparency for consumers with the need of businesses to keep their proprietary algorithms and systems protected. The CPPA should refrain from forcing businesses to make overly specific disclosures regarding automated decisionmaking processes to avoid mandating that they reveal information that could place them at a competitive disadvantage.

Finally, the Agency’s automated decisionmaking rules should be harmonized with other legal requirements related to automated processing to the extent such alignment is possible. Such harmonization would ensure Californians may exercise meaningful choices regarding automated decisionmaking processes as well as foster reliable consumer expectations about such processing. The Agency should prioritize adopting requirements related to automated decisionmaking that promote interoperability among state privacy laws, ensure Californians have a consistent and clear set of expectations about businesses’ automated decisionmaking activities, and simplify compliance efforts for businesses.

* * *

Thank you for the opportunity to submit these Comments in response to the Agency’s RFC. Please do not hesitate to contact us with any questions regarding this submission.

⁷ Cal. Civ. Code § 1798.185(a)(16).

⁸ *Id.*